QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

sigstore-js @ 769a53d87132 · Sigstore project — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-10-28 18:30 UTC
Версия отчёта	1
Запуск аудита	0c3b4262-640e-447a-928e-f22bd0d617ad · Документальный аудит · 2026-10-28 18:30 UTC
Версия анализатора	qsi-engine 1.2.0
Профиль риска	Разработчик ПО безопасности
SHA-256 содержимого	`dc5dfd0611af59e5724beaee5a3151159457f67dc81deebe8ed4ff09b683b1cb`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

28	1	10	11	4
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	1
Известная уязвимая версия компонента	21
Подтверждённая ошибка конфигурации	1
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	3
Рекомендация по улучшению	1
Недостаточность данных	1

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-05978	Критическая	proxy-addr 2.0.7 затронут GHSA-jqcg-44mw-7w3h (CVE-2026-90711)	40.7
QSI-2026-05957	Высокая	Закрытый ключ присутствует в packages/cli/src/signer.ts	78.0
QSI-2026-05955	Высокая	Срок действия сертификата истёк ((empty))	60.4
QSI-2026-05961	Высокая	brace-expansion 5.0.9 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)	37.7
QSI-2026-05963	Высокая	brace-expansion 5.0.9 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)	37.7

Неравенство Моски (x + y > z): x = 10, y = 3, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет. Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/sigstore/sigstore-js @ 769a53d8713248a8bf49edfc2a5d1955b0dcc24d — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

180 файлов, всего 751730 байт, редактирований: 1; список SHA-256 по файлам — в приложении C.

Методология

Аудит выполнен движком QSI 1.2.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Разработчик ПО безопасности», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Количество	Примеры
certificates_and_keys	проверено	2	DEMO.md: certificates/keys parsed; packages/cli/src/signer.ts: certificates/keys parsed
source_code	проверено	165	eslint.config.mjs: 22 lines scanned with 16 rule patterns and 122 registry patterns; jest.config.base.js: 23 lines scanned with 16 rule patterns and 122 registry patterns; jest.config.js: 26 lines scanned with 16 rule patterns and 122 registry patterns
dependencies	проверено	14	package-lock.json: 1062 dependencies parsed (1048 pinned); package.json: 24 dependencies parsed (10 pinned); packages/bundle/package.json: 1 dependencies parsed (0 pinned)
osv_advisories	проверено	1	863 pinned packages queried at OSV.dev; 18 affected (9 of them only in development or build dependencies)

Длинные списки здесь сгруппированы; полный список по файлам — в JSON-версии отчёта, подписанной тем же ключом.

Проверенные и непроверенные активы

Предоставленные входные данные: 181 (входные файлы: C)

Краткое описание архитектуры

Static review of the source tree sigstore-js at 769a53d8713248a8bf49edfc2a5d1955b0dcc24d. 180 files analysed; of 403 files, 149 are test, fuzzing, benchmark or example code and were left out, 74 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

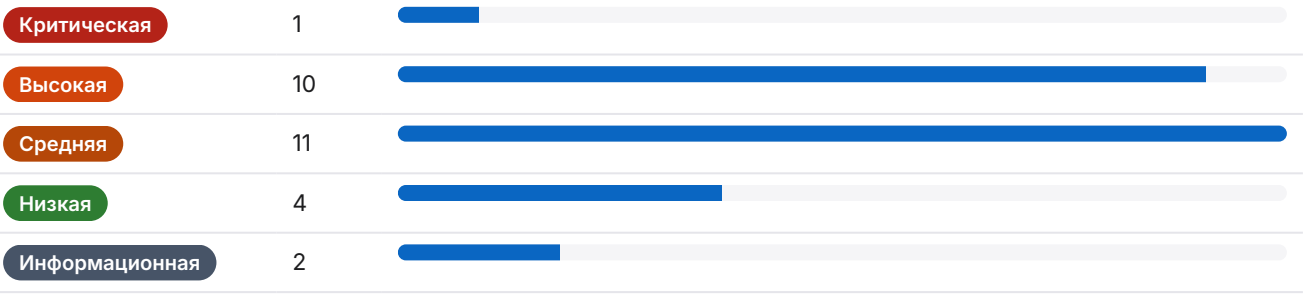
0
Ориентировочный индекс состояния (0–100)

30.0%
Доля квантово-уязвимых элементов инвентаризации

10
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-05978	proxy-addr 2.0.7 затронут GHSA-jqcg-44mw-7w3h (CVE-2026-90711)	Известная уязвимая версия компонента	Критическая	Низкая
QSI-2026-05957	Закрытый ключ присутствует в packages/cli/src/signer.ts	Подтверждённая техническая уязвимость	Высокая	Высокая
QSI-2026-05955	Срок действия сертификата истёк ((empty))	Подтверждённая ошибка конфигурации	Высокая	Высокая
QSI-2026-05961	brace-expansion 5.0.9 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05963	brace-expansion 5.0.9 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05964	body-parser 2.3.0 затронут GHSA-27r3-jxmh-p828 (CVE-2026-111181)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05965	brace-expansion 2.1.4 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05967	brace-expansion 2.1.4 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05969	http-cache-semantics 4.1.1 затронут GHSA-ch52-4w7c-c8xp (CVE-2026-93748)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05975	brace-expansion 1.1.18 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)	Известная уязвимая версия компонента	Высокая	Низкая
QSI-2026-05977	brace-expansion 1.1.18 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)	Известная уязвимая версия компонента	Высокая	Низкая

QSI-2026-05968	elliptic 6.6.1 затронут GHSA-848j-6mx2-7j84 (CVE-2025-14505)	Известная уязвимая версия компонента	Средняя	Средняя
QSI-2026-05962	brace-expansion 5.0.9 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05966	brace-expansion 2.1.4 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05970	ip-address 10.4.0 затронут GHSA-2vr4-cq9g-pvrc (CVE-2026-101910)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05971	ip-address 10.4.0 затронут GHSA-h3mg-xc3c-68pw (CVE-2026-101911)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05972	ip-address 10.4.0 затронут GHSA-j6r3-76f7-8jcv (CVE-2026-101912)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05973	ip-address 10.4.0 затронут GHSA-rpw4-54j3-4h4q (CVE-2026-101913)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05974	ip-address 10.4.0 затронут GHSA-rxp7-6hxx-x8q5 (CVE-2026-111997)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05976	brace-expansion 1.1.18 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05979	qs 6.15.2 затронут GHSA-4mjr-xmp4-gh2g (CVE-2026-82417)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05980	qs 6.15.2 затронут GHSA-6pq8-jhm2-2vcw (CVE-2026-110816)	Известная уязвимая версия компонента	Средняя	Низкая
QSI-2026-05958	Квантово-уязвимый ключ ECDSA (secp256r1) в packages/cli/src/signer.ts	Долгосрочный постквантовый риск	Низкая	Высокая
QSI-2026-05956	Квантово-уязвимый ключ ECDSA в сертификате ((empty))	Долгосрочный постквантовый риск	Низкая	Высокая
QSI-2026-05981	qs 6.15.2 затронут GHSA-x5fp-wj9c-mxmx (CVE-2026-82562)	Известная уязвимая версия компонента	Низкая	Низкая
QSI-2026-05959	Квантово-уязвимый ECDSA: роль не определена (1 файл(ов))	Долгосрочный постквантовый риск	Низкая	Средняя, предварительно

QSI-2026-05982	18 бюллетеней в 9 пакет(ах) npm, нужных только для разработки или сборки	Рекомендация по улучшению	Информационная	Средняя, предварительно
QSI-2026-05960	Не обнаружено криптобиблиотек с поддержкой PQC	Недостаточность данных	Информационная	Средняя, предварительно

Подробное описание находок

QSI-2026-05978 · DEP-KNOWN-ADVISORY

Критическая

proxy-addr 2.0.7 затронут GHSA-jqcg-44mw-7w3h (CVE-2026-90711)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-jqcg-44mw-7w3h (CVE-2026-90711) для пакета npm proxy-addr версии 2.0.7: proxy-addr vulnerable to IP spoofing via IPv4-mapped IPv6 trust subnet. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/proxy-addr@2.0.7
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	40.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	9.1 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-jqcg-44mw-7w3h
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-jqcg-44mw-7w3h · manifest · SHA-256 068ebda1c94e135a...


```
{"id": "GHSA-jqcg-44mw-7w3h", "aliases": ["CVE-2026-90711"], "modified":
"2026-10-05T23:45:07.322157228Z", "summary": "proxy-addr vulnerable to IP spoofing via IPv4-mapped
IPv6 trust subnet", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/
I:H/A:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (2.0.8).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-jqcg-44mw-7w3h

QSI-2026-05957 · KEY-PRIVATE-IN-INPUT

Высокая

Закрытый ключ присутствует в packages/cli/src/signer.ts

Подтверждённая техническая уязвимость | Уверенность: Высокая

Блок «EC PRIVATE KEY» найден в строке 5 файла packages/cli/src/signer.ts. QSI замаскировал ключ перед сохранением; исходный файл по-прежнему его содержит.

Затронутый актив	file:packages/cli/src/signer.ts
Источник данных	packages/cli/src/signer.ts
Метод обнаружения	Обнаружение PEM-заголовков.
Анализатор	certificates 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	78.0 / 100 (Разработчик ПО безопасности)
CVSS v3.1	8.1 — CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Любой, кто имеет доступ к файлу (репозиторий, резервные копии, журналы CI), может выдать себя за владельца ключа или расшифровать данные.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
grep -n 'PRIVATE KEY-----' packages/cli/src/signer.ts
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · packages/cli/src/signer.ts · line 5 · SHA-256 da98be3290bfbd0d… · Файл 26c2716645d88c4a…

```
Line 5: -----BEGIN EC PRIVATE KEY----- … [REDACTED BY QSI] … -----END …
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

QSI не может определить, используется ли ключ в продуктиве. Значение ключа не сохранялось.

РЕКОМЕНДАЦИЯ

Считайте ключ скомпрометированным: замените его, отзовите связанные сертификаты, удалите из истории версий, храните ключи в менеджере секретов/HSM.

ПОВТОРНАЯ ПРОВЕРКА

Найдите заголовки закрытых ключей в репозитории и его истории; убедитесь, что старый ключ отозван.

OWASP Application Security Verification Standard

QSI-2026-05955 · CERT-EXPIRED

Высокая

Срок действия сертификата истёк ((empty))

Подтверждённая ошибка конфигурации | Уверенность: Высокая

Срок действия сертификата X.509 с субъектом (empty) истёк 2023-08-11 (1173 дн. назад).

Затронутый актив	certificate:(empty)
Источник данных	DEMO.md
Метод обнаружения	Разбор X.509 (pyca/cryptography), сравнение notAfter с временем анализа (UTC).
Анализатор	certificates 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	60.4 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Клиенты, проверяющие сертификаты, откажут в соединении; пользователи могут привыкнуть игнорировать предупреждения.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
openssl x509 -in DEMO.md -noout -enddate
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

certificate · DEMO.md · line 167 · SHA-256 bae733af16eb1384… · Файл c2f21d5948090c47…

```
Subject:
Issuer: CN=sigstore-intermediate,O=sigstore.dev
Serial: 7831dfb1e8a745d9fb75a2bff19fc5c996cfddb2
Not before: 2023-08-11T19:18:53+00:00
Not after: 2023-08-11T19:28:53+00:00
Public key: ECDSA secp256r1
Signature algorithm: 1.2.840.10045.4.3.3 (ECDSA)
Signature hash: sha384
CA: False
SAN: -
SHA-256 fingerprint: ef251c2a0bee8fcc5748f8e887c4621a343add7926744dc5cc1a0d37ed10a70a
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Документальный анализ: исследован только предоставленный файл. Развёрнутая конфигурация может отличаться; результат относится к содержимому файла с зафиксированным SHA-256.

РЕКОМЕНДАЦИЯ

Перевыпустите сертификат и автоматизируйте продление (например, ACME) с мониторингом сроков.

ПОВТОРНАЯ ПРОВЕРКА

Повторно разберите развёрнутый сертификат и убедитесь, что notAfter в будущем.

NIST SP 800-57 Part 1 Rev. 5 — Recommendation for Key Management

QSI-2026-05961 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 5.0.9 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276) для пакета npm brace-expansion версии 5.0.9: brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@5.0.9
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-6j4f-fj2g-mc7p
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-6j4f-fj2g-mc7p · manifest · SHA-256 cf933227a5523b6f...


```
{"id": "GHSA-6j4f-fj2g-mc7p", "aliases": ["CVE-2026-102276"], "modified":
"2026-09-30T00:00:03.836613572Z", "summary": "brace-expansion: DoS via uncontrolled recursion in
parseCommaParts causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/
AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-6j4f-fj2g-mc7p

QSI-2026-05963 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 5.0.9 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278) для пакета npm brace-expansion версии 5.0.9: brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@5.0.9
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-qhr7-859c-m2p7
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-qhr7-859c-m2p7 · manifest · SHA-256 275e692c3e235281…


```
{"id": "GHSA-qhr7-859c-m2p7", "aliases": ["CVE-2026-102278"], "modified":
"2026-09-30T00:00:04.402763332Z", "summary": "brace-expansion: DoS via uncontrolled recursion on
nested brace groups causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/
AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-qhr7-859c-m2p7

QSI-2026-05964 · DEP-KNOWN-ADVISORY

Высокая

body-parser 2.3.0 затронут GHSA-27r3-jxmh-p828 (CVE-2026-111181)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-27r3-jxmh-p828 (CVE-2026-111181) для пакета npm body-parser версии 2.3.0: body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/body-parser@2.3.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-27r3-jxmh-p828
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-27r3-jxmh-p828 · manifest · SHA-256 d543d5d551c4905c…


```
{"id": "GHSA-27r3-jxmh-p828", "aliases": ["CVE-2026-111181"], "modified":
"2026-10-23T21:00:06.131613693Z", "summary": "body-parser vulnerable to Denial of Service via
```

```
trailing bytes after a compressed request body", "severity": [{"type": "CVSS_V3", "score":
"CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.20.9, 2.4.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-27r3-jxmh-p828

QSI-2026-05965 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 2.1.4 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276) для пакета npm brace-expansion версии 2.1.4: brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@2.1.4
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-6j4f-fj2g-mc7p
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-6j4f-fj2g-mc7p · manifest · SHA-256 cf933227a5523b6f…


```
{"id": "GHSA-6j4f-fj2g-mc7p", "aliases": ["CVE-2026-102276"], "modified":
"2026-09-30T00:00:03.836613572Z", "summary": "brace-expansion: DoS via uncontrolled recursion in
parseCommaParts causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/
AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг

Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-6j4f-fj2g-mc7p

QSI-2026-05967 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 2.1.4 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278) для пакета npm brace-expansion версии 2.1.4: brace-expansion: DoS via uncontrolled recursion on nested brace groups causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@2.1.4
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-qhr7-859c-m2p7
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-qhr7-859c-m2p7 · manifest · SHA-256 275e692c3e235281…


```
{"id": "GHSA-qhr7-859c-m2p7", "aliases": ["CVE-2026-102278"], "modified":
"2026-09-30T00:00:04.402763332Z", "summary": "brace-expansion: DoS via uncontrolled recursion on
nested brace groups causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/
AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-qhr7-859c-m2p7

QSI-2026-05969 · DEP-KNOWN-ADVISORY

Высокая

http-cache-semantics 4.1.1 затронут GHSA-ch52-4w7c-c8xp (CVE-2026-93748)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-ch52-4w7c-c8xp (CVE-2026-93748) для пакета npm http-cache-semantics версии 4.1.1: http-cache-semantics max-stale handling can disclose cross-user cached responses. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/http-cache-semantics@4.1.1
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-ch52-4w7c-c8xp
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-ch52-4w7c-c8xp · manifest · SHA-256 d2e17bba0ff48668...


```
{"id": "GHSA-ch52-4w7c-c8xp", "aliases": ["CVE-2026-93748"], "modified":
"2026-10-02T22:45:04.334960361Z", "summary": "http-cache-semantics max-stale handling can disclose
cross-user cached responses", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:L/PR:N/
UI:N/S:U/C:H/I:N/A:N"}, {"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/
VA:N/SC:N/SI:N/SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-ch52-4w7c-c8xp

QSI-2026-05975 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 1.1.18 затронут GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276) для пакета npm brace-expansion версии 1.1.18: brace-expansion: DoS via uncontrolled recursion in parseCommaParts causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@1.1.18
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-6j4f-fj2g-mc7p
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-6j4f-fj2g-mc7p · manifest · SHA-256 cf933227a5523b6f...


```
{"id": "GHSA-6j4f-fj2g-mc7p", "aliases": ["CVE-2026-102276"], "modified":
"2026-09-30T00:00:03.836613572Z", "summary": "brace-expansion: DoS via uncontrolled recursion in
parseCommaParts causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/
AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-6j4f-fj2g-mc7p

QSI-2026-05977 · DEP-KNOWN-ADVISORY

Высокая

brace-expansion 1.1.18 затронут GHSA-qhr7-859c-m2p7 (CVE-2026-102278)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278) для пакета npm brace-expansion версии 1.1.18: brace-expansion: DoS via uncontrolled recursion on nested brace groups

causing stack exhaustion. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@1.1.18
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	37.7 / 100 (Разработчик ПО безопасности)
CVSS v3.1	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-qhr7-859c-m2p7
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-qhr7-859c-m2p7 · manifest · SHA-256 275e692c3e235281…


```
{"id": "GHSA-qhr7-859c-m2p7", "aliases": ["CVE-2026-102278"], "modified":
"2026-09-30T00:00:04.402763332Z", "summary": "brace-expansion: DoS via uncontrolled recursion on
nested brace groups causing stack exhaustion", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/
AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-qhr7-859c-m2p7

QSI-2026-05968 · DEP-KNOWN-ADVISORY

Средняя

elliptic 6.6.1 затронут GHSA-848j-6mx2-7j84 (CVE-2025-14505)

Известная уязвимая версия компонента | Уверенность: Средняя

OSV.dev сообщает GHSA-848j-6mx2-7j84 (CVE-2025-14505) для пакета npm elliptic версии 6.6.1: Elliptic Uses a Cryptographic Primitive with a Risky Implementation. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/elliptic@6.6.1
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	44.3 / 100 (Разработчик ПО безопасности)

CVSS v3.1	5.6 — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-848j-6mx2-7j84
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-848j-6mx2-7j84 · manifest · SHA-256 b32797e721acee5f...


```
{"id": "GHSA-848j-6mx2-7j84", "aliases": ["CVE-2025-14505"], "modified":
"2026-09-10T03:50:32.794069999Z", "summary": "Elliptic Uses a Cryptographic Primitive with a Risky
Implementation", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/
I:L/A:L"}, {"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/
SA:N/E:P"}], "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-848j-6mx2-7j84

QSI-2026-05962 · DEP-KNOWN-ADVISORY

Средняя

brace-expansion 5.0.9 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277) для пакета npm brace-expansion версии 5.0.9: brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@5.0.9
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-q2hr-2g5m-vwhr
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-q2hr-2g5m-vwhr · manifest · SHA-256 798c3854b19c9033…


```
{"id": "GHSA-q2hr-2g5m-vwhr", "aliases": ["CVE-2026-102277"], "modified":
"2026-09-30T00:00:03.849541183Z", "summary": "brace-expansion: Quadratic-time expansion of the
`{a},b}` rewrite causes CPU denial of service", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/
AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-q2hr-2g5m-vwhr

QSI-2026-05966 · DEP-KNOWN-ADVISORY

Средняя

brace-expansion 2.1.4 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277) для пакета npm brace-expansion версии 2.1.4: brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@2.1.4
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-q2hr-2g5m-vwhr
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-q2hr-2g5m-vwhr · manifest · SHA-256 798c3854b19c9033…

{"id": "GHSA-q2hr-2g5m-vwhr", "aliases": ["CVE-2026-102277"], "modified": "2026-09-30T00:00:03.849541183Z", "summary": "brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L"}], "declared_in_manifest": false}

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-q2hr-2g5m-vwhr

QSI-2026-05970 · DEP-KNOWN-ADVISORY

Средняя

ip-address 10.4.0 затронут GHSA-2vr4-cq9g-pvrc (CVE-2026-101910)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-2vr4-cq9g-pvrc (CVE-2026-101910) для пакета npm ip-address версии 10.4.0: ip-address: no classifier recognizes the NAT64 local-use range 64:ff9b:1::/48, allowing SSRF and trust-boundary bypass. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/ip-address@10.4.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-2vr4-cq9g-pvrc
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-2vr4-cq9g-pvrc · manifest · SHA-256 23aa8f5aff217407…

{"id": "GHSA-2vr4-cq9g-pvrc", "aliases": ["CVE-2026-101910"], "modified": "2026-09-28T21:00:05.355682124Z", "summary": "ip-address: no classifier recognizes the NAT64 local-use range 64:ff9b:1::/48, allowing SSRF and trust-boundary bypass", "severity": [{"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:N/VA:N/SC:H/SI:N/SA:N"}], "declared_in_manifest": false}

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (10.5.1).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-2vr4-cq9g-pvrc

QSI-2026-05971 · DEP-KNOWN-ADVISORY

Средняя

ip-address 10.4.0 затронут GHSA-h3mg-xc3c-68pw (CVE-2026-101911)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-h3mg-xc3c-68pw (CVE-2026-101911) для пакета npm ip-address версии 10.4.0: ip-address: Address6 builds a parse diagnostic proportional to the input with no length bound, allowing a single long string to stall or crash the process. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/ip-address@10.4.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-h3mg-xc3c-68pw
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-h3mg-xc3c-68pw · manifest · SHA-256 084104e164917fcb...


```
{"id": "GHSA-h3mg-xc3c-68pw", "aliases": ["CVE-2026-101911"], "modified":
"2026-09-30T00:00:04.407982988Z", "summary": "ip-address: Address6 builds a parse diagnostic
proportional to the input with no length bound, allowing a single long string to stall or crash the
process", "severity": [{"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/
VA:L/SC:N/SI:N/SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (10.7.1).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-h3mg-xc3c-68pw

QSI-2026-05972 · DEP-KNOWN-ADVISORY

Средняя

ip-address 10.4.0 затронут GHSA-j6r3-76f7-8jcv (CVE-2026-101912)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-j6r3-76f7-8jcv (CVE-2026-101912) для пакета npm ip-address версии 10.4.0: ip-address: isInSubnet() and isHostInSubnet() compare addresses of different families as if they shared an address space, allowing an allowlist check to admit an address outside its range. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/ip-address@10.4.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-j6r3-76f7-8jcv
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-j6r3-76f7-8jcv · manifest · SHA-256 b9f0b89bd954b0b0...


```
{"id": "GHSA-j6r3-76f7-8jcv", "aliases": ["CVE-2026-101912"], "modified":
"2026-09-30T00:00:03.843448355Z", "summary": "ip-address: isInSubnet() and isHostInSubnet() compare
addresses of different families as if they shared an address space, allowing an allowlist check to
admit an address outside its range", "severity": [{"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/
AT:P/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (10.7.1).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-j6r3-76f7-8jcv

QSI-2026-05973 · DEP-KNOWN-ADVISORY

Средняя

ip-address 10.4.0 затронут GHSA-rpw4-54j3-4h4q (CVE-2026-101913)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-rpw4-54j3-4h4q (CVE-2026-101913) для пакета npm ip-address версии 10.4.0: ip-address: Address6.isLinkLocal() recognizes fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/ip-address@10.4.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-rpw4-54j3-4h4q
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-rpw4-54j3-4h4q · manifest · SHA-256 dc0bdf91e8de82df...


```
{"id": "GHSA-rpw4-54j3-4h4q", "aliases": ["CVE-2026-101913"], "modified":
"2026-09-28T21:00:05.359993143Z", "summary": "ip-address: Address6.isLinkLocal() recognizes
fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts",
"severity": [{"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/
SI:N/SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (10.5.1).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-rpw4-54j3-4h4q

QSI-2026-05974 · DEP-KNOWN-ADVISORY

Средняя

ip-address 10.4.0 затронут GHSA-rxp7-6hxx-x8q5 (CVE-2026-111997)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-rxp7-6hxx-x8q5 (CVE-2026-111997) для пакета npm ip-address версии 10.4.0: ip-address: Address6 matches a zone identifier in quadratic time ahead of its length limit, allowing a single long string to stall the process. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/ip-address@10.4.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-rxp7-6hxx-x8q5
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-rxp7-6hxx-x8q5 · manifest · SHA-256 7dc8c20c8ae73d58…


```
{"id": "GHSA-rxp7-6hxx-x8q5", "aliases": ["CVE-2026-111997"], "modified":
"2026-10-22T16:30:30.129356757Z", "summary": "ip-address: Address6 matches a zone identifier in
quadratic time ahead of its length limit, allowing a single long string to stall the process",
"severity": [{"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/
SI:N/SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (10.7.4).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-rxp7-6hxx-x8q5

QSI-2026-05976 · DEP-KNOWN-ADVISORY

Средняя

brace-expansion 1.1.18 затронут GHSA-q2hr-2g5m-vwhr (CVE-2026-102277)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277) для пакета npm brace-expansion версии 1.1.18: brace-expansion: Quadratic-time expansion of the `{a},b}` rewrite causes CPU denial of service. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/brace-expansion@1.1.18
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-q2hr-2g5m-vwhr
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-q2hr-2g5m-vwhr · manifest · SHA-256 798c3854b19c9033…


```
{"id": "GHSA-q2hr-2g5m-vwhr", "aliases": ["CVE-2026-102277"], "modified":
"2026-09-30T00:00:03.849541183Z", "summary": "brace-expansion: Quadratic-time expansion of the
`{a},b}` rewrite causes CPU denial of service", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/
AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-q2hr-2g5m-vwhr

QSI-2026-05979 · DEP-KNOWN-ADVISORY

Средняя

qs 6.15.2 затронут GHSA-4mjr-xmp4-gh2g (CVE-2026-82417)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-4mjr-xmp4-gh2g (CVE-2026-82417) для пакета npm qs версии 6.15.2: qs: Denial of Service via Attacker Controlled isBuffer. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/qs@6.15.2
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.

Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-4mjr-xmp4-gh2g
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-4mjr-xmp4-gh2g · manifest · SHA-256 afef9a11fcfc48b7...


```
{"id": "GHSA-4mjr-xmp4-gh2g", "aliases": ["CVE-2026-82417"], "modified":
"2026-09-10T03:51:14.991984096Z", "summary": "qs: Denial of Service via Attacker Controlled
isBuffer", "severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/
A:L"}, {"type": "CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/
SA:N"}], "declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (6.16.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-4mjr-xmp4-gh2g

QSI-2026-05980 · DEP-KNOWN-ADVISORY

Средняя

qs 6.15.2 затронут GHSA-6pq8-jhm2-2vcw (CVE-2026-110816)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-6pq8-jhm2-2vcw (CVE-2026-110816) для пакета npm qs версии 6.15.2: qs : qs.stringify with arrayFormat 'comma' throws an uncaught TypeError on array elements carrying a non-callable own toString (DoS). Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/qs@6.15.2
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	33.2 / 100 (Разработчик ПО безопасности)
CVSS v3.1	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-6pq8-jhm2-2vcw
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-6pq8-jhm2-2vcw · manifest · SHA-256 4fd7af689173b0c3...


```
{"id": "GHSA-6pq8-jhm2-2vcw", "aliases": ["CVE-2026-110816"], "modified":
"2026-10-27T16:15:05.324423680Z", "summary": "qs : qs.stringify with arrayFormat 'comma' throws an
uncaught TypeError on array elements carrying a non-callable own toString (DoS)", "severity":
[{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L"}, {"type": "CVSS_V4",
"score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N"}],
"declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (6.16.1).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-6pq8-jhm2-2vcw

QSI-2026-05958 · KEY-QV-PUBLIC

Низкая

Квантово-уязвимый ключ ECDSA (secp256r1) в packages/cli/src/signer.ts

Долгосрочный постквантовый риск | Уверенность: Высокая

Найден открытый ключ ECDSA secp256r1 (строка 12).

Затронутый актив	file:packages/cli/src/signer.ts#line 12
Источник данных	packages/cli/src/signer.ts
Метод обнаружения	Разбор открытого ключа.
Анализатор	certificates 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	41.6 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=5.0, y=3.0, z=8.0 → запас минимален

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск при появлении CRQC; для обмена ключами записанный трафик может быть расшифрован задним числом.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте строка 12 в предоставленном файле packages/cli/src/signer.ts и изучите приведённые строки (см. доказательство).
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

key · packages/cli/src/signer.ts · line 12 · SHA-256 87a3decbb47c307b... · Файл 26c2716645d88c4a...

```
ECDSA public key, secp256r1
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня.

РЕКОМЕНДАЦИЯ

Внесите в инвентаризацию и запланируйте миграцию на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it..

ПОВТОРНАЯ ПРОВЕРКА

Повторный аудит после миграции.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards

QSI-2026-05956 · CERT-QV-KEY

Низкая

Квантово-уязвимый ключ ECDSA в сертификате ((empty))

Долгосрочный постквантовый риск | Уверенность: Высокая

Сертификат (empty) использует открытый ключ ECDSA secp256r1, действителен до 2023-08-11. ECDSA взламывается алгоритмом Шора на CRQC.

Затронутый актив	certificate:(empty)
Источник данных	DEMO.md
Метод обнаружения	Определение алгоритма открытого ключа X.509.
Анализатор	certificates 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	38.1 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=0.0, y=3.0, z=8.0 → при этом сценарии время есть

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Для аутентификации риск реализуется только если CRQC появится, пока ключ/сертификат ещё доверенный. Сертификаты короткоживущие, поэтому основной вопрос — PKI и долгоживущие корневые/промежуточные сертификаты.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
openssl x509 -in DEMO.md -noout -text | grep -A2 'Public Key Algorithm'
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

certificate · DEMO.md · line 167 · SHA-256 bae733af16eb1384... · Файл c2f21d5948090c47...

```
Subject:
Issuer: CN=sigstore-intermediate,O=sigstore.dev
Serial: 7831dfb1e8a745d9fb75a2bff19fc5c996cfddb2
Not before: 2023-08-11T19:18:53+00:00
Not after: 2023-08-11T19:28:53+00:00
Public key: ECDSA secp256r1
Signature algorithm: 1.2.840.10045.4.3.3 (ECDSA)
Signature hash: sha384
CA: False
SAN: -
SHA-256 fingerprint: ef251c2a0bee8fcc5748f8e887c4621a343add7926744dc5cc1a0d37ed10a70a
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня.

РЕКОМЕНДАЦИЯ

Учитывайте в PQC-инвентаризации; используйте короткие сроки действия; следуйте рекомендациям CA/Browser Forum и NIST по переходу на сертификаты ML-DSA.

ПОВТОРНАЯ ПРОВЕРКА

Повторите аудит после внедрения PQC или гибридных сертификатов.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-05981 · DEP-KNOWN-ADVISORY

Низкая

qs 6.15.2 затронут GHSA-x5fp-wj9c-mxmx (CVE-2026-82562)

Известная уязвимая версия компонента | Уверенность: Низкая

OSV.dev сообщает GHSA-x5fp-wj9c-mxmx (CVE-2026-82562) для пакета npm qs версии 6.15.2: qs array-limit bypass via bracket-key comma parsing. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:npm/qs@6.15.2
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	29.5 / 100 (Разработчик ПО безопасности)
CVSS v3.1	3.7 — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Зависит от достижимости уязвимого кода в вашем приложении.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GHSA-x5fp-wj9c-mxmx
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GHSA-x5fp-wj9c-mxmx · manifest · SHA-256 ab9f70e61d9bf8b7…

```
{"id": "GHSA-x5fp-wj9c-mxmx", "aliases": ["CVE-2026-82562"], "modified":
"2026-09-10T03:50:54.569331980Z", "summary": "qs array-limit bypass via bracket-key comma parsing",
"severity": [{"type": "CVSS_V3", "score": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L"}, {"type":
"CVSS_V4", "score": "CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N"}],
"declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Обновите до исправленной версии (6.16.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GHSA-x5fp-wj9c-mxmx

QSI-2026-05959 · CODE-QV-ASYMMETRIC

Низкая

Квантово-уязвимый ECDSA: роль не определена (1 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

1 упоминаний ECDSA в 1 файл(ах), например packages/conformance/src/commands/verify-bundle.ts:189. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:ECDSA:general
Источник данных	packages/conformance/src/commands/verify-bundle.ts
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	28.3 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=5.0, y=3.0, z=8.0 → запас минимален

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте packages/conformance/src/commands/verify-bundle.ts:189 и проверьте приведённые строки;
остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · packages/conformance/src/commands/verify-bundle.ts · line 189 · SHA-256 ec59ccc9dd99b340… · Файл 51b04961ad1221e9…

```
188 |   switch (curve) {
189 |     case 'prime256v1':
190 |       return new EC('p256');
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-05982 · DEP-ADVISORY-DEV

Информационная

18 бюллетеней в 9 пакет(ах) npm, нужных только для разработки или сборки

Рекомендация по улучшению | Уверенность: Средняя | предварительно — требует дополнительной проверки

OSV.dev сообщает 18 бюллетеней (10 с оценкой high или critical) для 9 пакет(ов) npm, которые подтягивают только инструменты разработки или сборки (package-lock.json): например, @babel/core@7.29.0 [dev]: GHSA-4x5r-pxfx-6jf8; @humanfs/node@0.16.6 [dev]: GHSA-p498-v437-472g; baseline-browser-mapping@2.10.31 [dev]: GHSA-w5vr-8v7q-w6rv; browserslist@4.28.2 [dev]: GHSA-73wf-gq98-2v4g, GHSA-c83g-rgw3-j3cx; deepmerge@4.3.1 [dev]: GHSA-gcqx-w48m-w2h4. Манифесты помечают их так (devDependencies, "dev": true в package-lock.json, [dev-dependencies]/[build-dependencies] через граф Cargo.lock), поэтому в поставляемый продукт они не входят.

Затронутый актив	dependencies:npm:non-runtime
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch по точным версиям; область применения — из devDependencies, флагов dev в package-lock.json, разделов importers в pnpm, графа Cargo.lock от таблиц Cargo.toml и — для yarn.lock, который область не записывает вовсе — графа файла блокировки, пройденного от package.json. Если рабочее требование в файле блокировки разрешить не удалось, файл остаётся без классификации, чтобы пакет не был отложен в сторону по ошибке.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	15.3 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Пользователей продукта они не затрагивают. Они могут влиять на машины разработчиков и CI (цепочка поставки): скомпрометированный или уязвимый инструмент способен изменить сборку.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Найдите пакеты из доказательства на https://osv.dev и проверьте их область применения в package-lock.json.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev (npm) · package-lock.json · SHA-256 dd8749c12d599485…

```
@babel/core@7.29.0 [dev]: GHSA-4x5r-pxfx-6jf8
@humanfs/node@0.16.6 [dev]: GHSA-p498-v437-472g
baseline-browser-mapping@2.10.31 [dev]: GHSA-w5vr-8v7q-w6rv
browserslist@4.28.2 [dev]: GHSA-73wf-gq98-2v4g, GHSA-c83g-rgw3-j3cx
deepmerge@4.3.1 [dev]: GHSA-gcqx-w48m-w2h4
diff@4.0.2 [dev]: GHSA-73rr-hh4g-fpgx
handlebars@4.7.9 [dev]: GHSA-8r5x-fm3f-whwj, GHSA-p8wg-vrv2-v86f, GHSA-xw65-4hp5-5hc7
js-yaml@3.14.2 [dev]: GHSA-2883-xcg3-v3hh, GHSA-52cp-r559-cp3m, GHSA-5p4m-2wfm-xmqj, GHSA-h67p-54hq-rp68
js-yaml@4.1.1 [dev]: GHSA-2883-xcg3-v3hh, GHSA-52cp-r559-cp3m, GHSA-5p4m-2wfm-xmqj, GHSA-h67p-54hq-rp68
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные получены от OSV.dev в зафиксированное время. Области применения взяты из манифестов; собственные build-зависимости крейтов реестра в Cargo.lock не различимы, поэтому множество runtime может оказаться больше реального, но не меньше.

РЕКОМЕНДАЦИЯ

Обновите инструменты в рамках планового обслуживания; в первую очередь пакеты, которые выполняются в CI с секретами или создают релизные артефакты.

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV.dev — open-source vulnerability database and API

QSI-2026-05960 · DEP-NO-PQC-LIBRARY

Информационная

Не обнаружено криптобиблиотек с поддержкой PQC

Недостаточность данных | Уверенность: Средняя | предварительно — требует дополнительной проверки

В 14 манифестах зависимостей QSI нашёл криптобиблиотеки (@noble/hashes, elliptic, jose), но ни одной из списка поддерживающих PQC.

Затронутый актив	dependencies
Источник данных	dependency manifests
Метод обнаружения	Сопоставление названий зависимостей.
Анализатор	dependencies 1.2.0 · 2026-10-28 18:30 UTC
Балл приоритета	13.5 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Только индикатор готовности: поддержка PQC может обеспечиваться платформой (OpenSSL, ОС, облачный KMS), а не зависимостями приложения.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Изучите перечисленные в доказательстве манифесты.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

dependency · package-lock.json, package.json, packages/bundle/package.json, packages/cli/package.json, packages/client/package.json, packages/conformance/package.json, packages/core/package.json, packages/jest/package.json, packages/jest-types/package.json, packages/oci/package.json, packages/rekor-types/package.json, packages/sign/package.json, packages/tuf/package.json, packages/verify/package.json · SHA-256 be9f89f81d86a21d…

```
Crypto libraries: @noble/hashes, elliptic, jose
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Отсутствие доказательств не является доказательством отсутствия: системные библиотеки и транзитивные зависимости могут не указываться.

РЕКОМЕНДАЦИЯ

Определите источник поддержки PQC (TLS-терминатор, KMS/HSM, обновление библиотек).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование после обновлений.

FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM); FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA)

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-05978	tool_output	OSV.dev GHSA-jqcg-44mw-7w3h (manifest)	068ebda1c94e135a6ba184368cc0247de44a750d8b4a53b327cb3256fede
QSI-2026-05957	file_excerpt	packages/cli/src/signer.ts (line 5)	da98be3290bfbd0dae64a05e2bc855eb234b8db812572a82f6d956a7f448
QSI-2026-05955	certificate	DEMO.md (line 167)	bae733af16eb1384eaa5f82f716c90884517dea53f84b4fa7ba3359f03f6
QSI-2026-05961	tool_output	OSV.dev GHSA-6j4f-fj2g-mc7p (manifest)	cf933227a5523b6f51c16be2051db199cf5f5331c14d818f4a5f8948452
QSI-2026-05963	tool_output	OSV.dev GHSA-qhr7-859c-m2p7 (manifest)	275e692c3e2352812e486e115c46ddfbc08d41860e0602c22f5e55a57cd2
QSI-2026-05964	tool_output	OSV.dev GHSA-27r3-jxmh-p828 (manifest)	d543d5d551c4905cfb479113347b1052576dde0acd9bf492cd62c4e048d1
QSI-2026-05965	tool_output	OSV.dev GHSA-6j4f-fj2g-mc7p (manifest)	cf933227a5523b6f51c16be2051db199cf5f5331c14d818f4a5f8948452
QSI-2026-05967	tool_output	OSV.dev GHSA-qhr7-859c-m2p7 (manifest)	275e692c3e2352812e486e115c46ddfbc08d41860e0602c22f5e55a57cd2
QSI-2026-05969	tool_output	OSV.dev GHSA-ch52-4w7c-c8xp (manifest)	d2e17bba0ff4866810601d6c02a22d519e24e081a42a021187f27dfc6ad3
QSI-2026-05975	tool_output	OSV.dev GHSA-6j4f-fj2g-mc7p (manifest)	cf933227a5523b6f51c16be2051db199cf5f5331c14d818f4a5f8948452
QSI-2026-05977	tool_output	OSV.dev GHSA-qhr7-859c-m2p7 (manifest)	275e692c3e2352812e486e115c46ddfbc08d41860e0602c22f5e55a57cd2
QSI-2026-05968	tool_output	OSV.dev GHSA-848j-6mx2-7j84 (manifest)	b32797e721acee5f454dcfa7a91f9741d677253a0d002c941a32a62a1f72
QSI-2026-05962	tool_output	OSV.dev GHSA-g2hr-2g5m-vwhr (manifest)	798c3854b19c9033c4e4ebcc2656a9cbdd2e1551dfba1a6307865066fff2
QSI-2026-05966	tool_output	OSV.dev GHSA-g2hr-2g5m-vwhr (manifest)	798c3854b19c9033c4e4ebcc2656a9cbdd2e1551dfba1a6307865066fff2
QSI-2026-05970	tool_output	OSV.dev GHSA-2vr4-cq9g-pvrc (manifest)	23aa8f5aff21740715edc1a3a04428e67595ae44752ff208884973de7c05
QSI-2026-05971	tool_output	OSV.dev GHSA-h3mg-xc3c-68pw (manifest)	084104e164917fcb371e479d007af8b749882c861c64fcacd02041d6e282

QSI-2026-05972	tool_output	OSV.dev GHSA-j6r3-76f7-8jcv (manifest)	b9f0b89bd954b0b0d9c1b4d78cdd26b719df1b9c13c106e6d87c1add480a
QSI-2026-05973	tool_output	OSV.dev GHSA-rpw4-54j3-4h4q (manifest)	dc0bdf91e8de82dfc03986ef28acb52ed28cd0fe6e1c47fb73ddb402120c
QSI-2026-05974	tool_output	OSV.dev GHSA-rxp7-6hxx-x8q5 (manifest)	7dc8c20c8ae73d58d9b3ae97df00f6c5b5020d9aba1bf5eaa5bb382651e4
QSI-2026-05976	tool_output	OSV.dev GHSA-q2hr-2g5m-vwhr (manifest)	798c3854b19c9033c4e4ebcc2656a9cbdd2e1551dfba1a6307865066fff2
QSI-2026-05979	tool_output	OSV.dev GHSA-4mjr-xmp4-gh2g (manifest)	afef9a11fcfc48b7311cfed5a422a080a74b3276138000786083623b479
QSI-2026-05980	tool_output	OSV.dev GHSA-6pq8-jhm2-2vcw (manifest)	4fd7af689173b0c3abc4f3e9006070e7de778a692b621288cc277cd4bcb7
QSI-2026-05958	key	packages/cli/src/signer.ts (line 12)	87a3decbb47c307b59a5585db9eecff49e5997a1eb7350dbfae08a97c0f3
QSI-2026-05956	certificate	DEMO.md (line 167)	bae733af16eb1384eaa5f82f716c90884517dea53f84b4fa7ba3359f03f6
QSI-2026-05981	tool_output	OSV.dev GHSA-x5fp-wj9c-mxmx (manifest)	ab9f70e61d9bf8b7815b971ebbe0469a1cc4a588076113a5a3c86ff35cdc
QSI-2026-05959	file_excerpt	packages/conformance/src/commands/verify-bundle.ts (line 189)	ec59ccc9dd99b3400e4b9c1ad39a0fe13844789c4506617af5c7fc0bfe12
QSI-2026-05982	tool_output	OSV.dev (npm) (package-lock.json)	dd8749c12d599485dd3800e3d80f69c545b7fbcd175e3eb280e5c58c9d56

QSI-2026-05960	dependency	package-lock.json, package.json, packages/bundle/ package.json, packages/cli/ package.json, packages/client/ package.json, packages/ conformance/ package.json, packages/core/ package.json, packages/jest/ package.json, packages/jest-types/ package.json, packages/oci/ package.json, packages/rekor-types/ package.json, packages/sign/ package.json, packages/tuf/ package.json, packages/verify/ package.json	be9f89f81d86a21db4093cb67ce699dea602e96a88023e0893120c90271c

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	5
Время миграции y	3	3
Принятое число лет до CRQC z	8 (early)	8
x + y − z	5 → при этом сценарии миграция завершится слишком поздно	0 → запас минимален

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Разработчик ПО безопасности», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
роль не определена	ECDSA (1)	QSI-2026-05959	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество
сниженный запас (Гровер), одобрен	1
Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	1
н/п	5
уязвим (Шор)	3

Подробное описание находок: QSI-2026-05958, QSI-2026-05956, QSI-2026-05959

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — дискретный логарифм на эллиптических кривых Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	ECDSA (3)	Ключи на эллиптических кривых, по оценкам, падут раньше ключей RSA сопоставимой классической стойкости. В блокчейнах первыми под угрозой монеты, чей открытый ключ уже опубликован (повторно используемые адреса, выходы pay-to-public-key и Taproot); планируйте переход на постквантовые подписи и до этого избегайте повторного использования ключей.
Алгоритм Гровера — поиск ключа и прообразов Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (2)	Не взлом. Ключи 256 бит (AES-256, ChaCha20) сохраняют хороший запас; AES-128 соответствует категории 1 NIST, но некоторые регуляторы требуют 256-битных ключей в квантово-устойчивых системах (см. запись AES-128). Для долгоживущих данных предпочитайте 256-битные ключи; 256-битные хеши для стойкости к прообразам менять не нужно.
Брассар–Хойер–Тапп — поиск коллизий Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (2)	256-битные хеши (SHA-256, SHA3-256) остаются достаточными по стойкости к коллизиям; 160-битные хеши слабы уже классически (коллизии SHA-1 практичны). Где нужны категории NIST 4–5, используйте хеши на 384/512 бит.

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

План устранения проблем

QSI-2026-05957 · P1 · 30 дн. краткосрочное снижение риска

Немедленно отзовите/замените ключ из packages/cli/src/signer.ts и ограничьте доступ к файлу.

Обоснование	Сокращает окно злоупотребления.
Ожидаемый результат	Раскрытый ключ больше не является доверенным.
Сложность	low
Зависимости	Владелец ключа, доступ к УЦ.
Побочные эффекты	Сервисы, использующие ключ, потребуют передеплоя.
Тесты до изменения	Определите все системы, использующие ключ (по отпечатку).
Тесты после изменения	Подтвердите отзыв (CRL/OCSP) и использование нового ключа.
Условие закрытия	Старый ключ отозван, новый развёрнут.

QSI-2026-05955 · P1 · 30 дн. устранение первопричины

Перевыпустите сертификат для (empty) и включите автоматическое продление с оповещением не позднее чем за 30 дней.

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Не ожидаются.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Развёрнутый сертификат действителен, продление автоматизировано.

QSI-2026-05978 · P2 · 30 дн. устранение первопричины

Обновите proxy-addr до исправленной версии (2.0.8).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-jqcg-44mw-7w3h (CVE-2026-90711).

QSI-2026-05961 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

Обоснование	Устраняет первопричину, описанную в находке.

Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276).

QSI-2026-05963 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278).

QSI-2026-05964 · P2 · 30 дн. устранение первопричины

Обновите body-parser до исправленной версии (1.20.9, 2.4.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-27r3-jxmh-p828 (CVE-2026-111181).

QSI-2026-05965 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.

Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276).

QSI-2026-05967 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278).

QSI-2026-05969 · P2 · 30 дн. устранение первопричины

Обновите http-cache-semantics до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-ch52-4w7c-c8xp (CVE-2026-93748).

QSI-2026-05975 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-6j4f-fj2g-mc7p (CVE-2026-102276).

QSI-2026-05977 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-qhr7-859c-m2p7 (CVE-2026-102278).

QSI-2026-05968 · P2 · 30 дн. устранение первопричины

Обновите elliptic до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-848j-6mx2-7j84 (CVE-2025-14505).

QSI-2026-05962 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277).

QSI-2026-05966 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.

Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277).

QSI-2026-05970 · P2 · 30 дн. устранение первопричины

Обновите ip-address до исправленной версии (10.5.1).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-2vr4-cq9g-pvrc (CVE-2026-101910).

QSI-2026-05971 · P2 · 30 дн. устранение первопричины

Обновите ip-address до исправленной версии (10.7.1).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-h3mg-xc3c-68pw (CVE-2026-101911).

QSI-2026-05972 · P2 · 30 дн. устранение первопричины

Обновите ip-address до исправленной версии (10.7.1).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	

	Сканирование зависимостей больше не сообщает GHSA-j6r3-76f7-8jcv (CVE-2026-101912).

QSI-2026-05973 · P2 · 30 дн. устранение первопричины

Обновите ip-address до исправленной версии (10.5.1).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-rpw4-54j3-4h4q (CVE-2026-101913).

QSI-2026-05974 · P2 · 30 дн. устранение первопричины

Обновите ip-address до исправленной версии (10.7.4).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-rxp7-6hxx-x8q5 (CVE-2026-111997).

QSI-2026-05976 · P2 · 30 дн. устранение первопричины

Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-q2hr-2g5m-vwhr (CVE-2026-102277).

QSI-2026-05979 · P2 · 30 дн. устранение первопричины

Обновите qs до исправленной версии (6.16.0).

Обоснование	Устраняет первопричину, описанную в находке.

Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-4mjr-xmp4-gh2g (CVE-2026-82417).

QSI-2026-05980 · P2 · 30 дн. устранение первопричины

Обновите qs до исправленной версии (6.16.1).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-6pq8-jhm2-2vcw (CVE-2026-110816).

QSI-2026-05981 · P2 · 30 дн. устранение первопричины

Обновите qs до исправленной версии (6.16.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование зависимостей больше не сообщает GHSA-x5fp-wj9c-mxmx (CVE-2026-82562).

QSI-2026-05957 · P1 · 60 дн. устранение первопричины

Перенесите хранение ключей в менеджер секретов или HSM; добавьте сканирование секретов в CI и pre-commit; очистите историю.

Обоснование	Предотвращает повторение.
Ожидаемый результат	Ключи не попадают в репозиторий.
Сложность	medium
Зависимости	Менеджер секретов.
Побочные эффекты	Переписывание истории затронет клоны.
Тесты до изменения	Запустите сканер секретов по репозиторию.

Тесты после изменения	Сканер не находит закрытых ключей; CI блокирует новые.
Условие закрытия	Сканирование секретов обязательно в CI; ключей в истории нет.

QSI-2026-05958 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования ECDSA в file:packages/cli/src/signer.ts в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-05956 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования ECDSA в certificate:(empty) в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-05959 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.

Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-05958 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. или гибридной схемы.

QSI-2026-05956 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. или гибридной схемы.

QSI-2026-05959 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема или гибридной схемы.

QSI-2026-05982 · P4 · 90 дн. устранение первопричины

Обновите зависимости разработки и сборки из доказательства.

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Обновление инструментов может изменить результат сборки; сравните релизные артефакты.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование не сообщает бюллетеней для пакетов инструментов, либо оставшиеся зафиксированы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
P1	QSI-2026-05957	Немедленно отзовите/замените ключ из packages/cli/src/signer.ts и ограничьте доступ к файлу.	краткосрочное снижение риска
P1	QSI-2026-05955	Перевыпустите сертификат для (empty) и включите автоматическое продление с оповещением не позднее чем за 30 дней.	устранение первопричины
P2	QSI-2026-05978	Обновите proxy-addr до исправленной версии (2.0.8).	устранение первопричины
P2	QSI-2026-05961	Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).	устранение первопричины
P2	QSI-2026-05963	Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).	устранение первопричины
P2	QSI-2026-05964	Обновите body-parser до исправленной версии (1.20.9, 2.4.0).	устранение первопричины
P2	QSI-2026-05965	Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).	устранение первопричины
P2	QSI-2026-05967	Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).	устранение первопричины
P2	QSI-2026-05969	Обновите http-cache-semantics до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).	устранение первопричины
P2	QSI-2026-05975	Обновите brace-expansion до исправленной версии (1.1.19, 2.1.5, 3.0.7, 5.0.10).	устранение первопричины
P2	QSI-2026-05977	Обновите brace-expansion до исправленной версии (1.1.20, 2.1.6, 3.0.8, 5.0.11).	устранение первопричины
P2	QSI-2026-05968	Обновите elliptic до исправленной версии (пока не выпущена; меры смягчения — в бюллетене).	устранение первопричины
P2	QSI-2026-05962	Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).	устранение первопричины
P2	QSI-2026-05966	Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).	устранение первопричины
P2	QSI-2026-05970	Обновите ip-address до исправленной версии (10.5.1).	устранение первопричины
P2	QSI-2026-05971	Обновите ip-address до исправленной версии (10.7.1).	устранение первопричины
P2	QSI-2026-05972	Обновите ip-address до исправленной версии (10.7.1).	устранение первопричины
P2	QSI-2026-05973	Обновите ip-address до исправленной версии (10.5.1).	устранение первопричины

P2	QSI-2026-05974	Обновите ip-address до исправленной версии (10.7.4).	устранение первопричины
P2	QSI-2026-05976	Обновите brace-expansion до исправленной версии (1.1.21, 2.1.7, 3.0.9, 5.0.12).	устранение первопричины
P2	QSI-2026-05979	Обновите qs до исправленной версии (6.16.0).	устранение первопричины
P2	QSI-2026-05980	Обновите qs до исправленной версии (6.16.1).	устранение первопричины
P2	QSI-2026-05981	Обновите qs до исправленной версии (6.16.0).	устранение первопричины

60 дн.

Приоритет	ID	Действие	Тип
P1	QSI-2026-05957	Перенесите хранение ключей в менеджер секретов или HSM; добавьте сканирование секретов в CI и pre-commit; очистите историю.	устранение первопричины

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-05958	Внесите использования ECDSA в file:packages/cli/src/signer.ts в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P3	QSI-2026-05956	Внесите использования ECDSA в certificate:(empty) в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P3	QSI-2026-05959	Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-05958	Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-05956	Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины

P4	QSI-2026-05959	Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-05982	Обновите зависимости разработки и сборки из доказательства.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-05978	Повторите сканирование зависимостей после обновления.
QSI-2026-05957	Найдите заголовки закрытых ключей в репозитории и его истории; убедитесь, что старый ключ отозван.
QSI-2026-05955	Повторно разберите развёрнутый сертификат и убедитесь, что notAfter в будущем.
QSI-2026-05961	Повторите сканирование зависимостей после обновления.
QSI-2026-05963	Повторите сканирование зависимостей после обновления.
QSI-2026-05964	Повторите сканирование зависимостей после обновления.
QSI-2026-05965	Повторите сканирование зависимостей после обновления.
QSI-2026-05967	Повторите сканирование зависимостей после обновления.
QSI-2026-05969	Повторите сканирование зависимостей после обновления.
QSI-2026-05975	Повторите сканирование зависимостей после обновления.
QSI-2026-05977	Повторите сканирование зависимостей после обновления.
QSI-2026-05968	Повторите сканирование зависимостей после обновления.
QSI-2026-05962	Повторите сканирование зависимостей после обновления.
QSI-2026-05966	Повторите сканирование зависимостей после обновления.
QSI-2026-05970	Повторите сканирование зависимостей после обновления.
QSI-2026-05971	Повторите сканирование зависимостей после обновления.
QSI-2026-05972	Повторите сканирование зависимостей после обновления.
QSI-2026-05973	Повторите сканирование зависимостей после обновления.
QSI-2026-05974	Повторите сканирование зависимостей после обновления.
QSI-2026-05976	Повторите сканирование зависимостей после обновления.
QSI-2026-05979	Повторите сканирование зависимостей после обновления.
QSI-2026-05980	Повторите сканирование зависимостей после обновления.
QSI-2026-05958	Повторный аудит после миграции.
QSI-2026-05956	Повторите аудит после внедрения PQC или гибридных сертификатов.
QSI-2026-05981	Повторите сканирование зависимостей после обновления.
QSI-2026-05959	Повторите инвентаризацию после рефакторинга.
QSI-2026-05982	Повторите сканирование зависимостей после обновления.
QSI-2026-05960	Повторите сканирование после обновлений.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.1.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.2.0
inventory_document	1.1.0
solidity	1.2.0
source_code	1.3.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.2.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. A. Chailloux, M. Naya-Plasencia, A. Schrottenloher — An Efficient Quantum Collision Search Algorithm and Implications on Symmetric Cryptography (ASIACRYPT 2017; IACR ePrint 2017/847) — IACR ePrint. https://eprint.iacr.org/2017/847 (peer-reviewed article: Õ(2^{2n/5}) time, O(n) qubits, Õ(2^{n/5}) classical memory)
2. C. Chevignard, P.-A. Fouque, A. Schrottenloher — Reducing the Number of Qubits in Quantum Discrete Logarithms on Elliptic Curves (IACR ePrint 2026/280) — IACR ePrint. https://eprint.iacr.org/2026/280 (revision of a EUROCRYPT 2026 paper: 3.12n + o(n) qubits; for n = 256, 1193 qubits and 22 runs of 2^38.98 Toffoli gates)
3. C. Zalka — Grover's quantum searching algorithm is optimal (Phys. Rev. A 60, 2746, 1999; arXiv:quant-ph/9711070) — APS. https://doi.org/10.1103/PhysRevA.60.2746 (peer-reviewed article: optimal for any success probability; parallel search gains no more than splitting the space)
4. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
5. D. J. Bernstein — Cost analysis of hash collisions: Will quantum computers make SHARCS obsolete? (2009) — cr.yp.to. https://cr.yp.to/hash/collisioncost-20090823.pdf (paper dated 2009-08-23)
6. D. Litinski — How to compute a 256-bit elliptic curve private key with only 50 million Toffoli gates (arXiv:2306.08585) — arXiv. https://arxiv.org/abs/2306.08585 (preprint (2023-06-14): 6000 modules × 1152 physical qubits, one key per 10 minutes under its architecture assumptions)
7. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
8. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
9. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
10. G. Brassard, P. Høyer, A. Tapp — Quantum Algorithm for the Collision Problem (LATIN '98; arXiv:quant-ph/9705002) — Springer / arXiv. https://arxiv.org/abs/quant-ph/9705002 (peer-reviewed article: collisions of r-to-one functions in O((N/r)^{1/3}) expected evaluations)
11. J. Proos, C. Zalka — Shor's discrete logarithm quantum algorithm for elliptic curves (Quantum Inf. Comput. 3(4), 2003; arXiv:quant-ph/0301141) — Quantum Information & Computation. https://doi.org/10.26421/QIC3.4-3 (peer-reviewed article)
12. L. K. Grover — A fast quantum mechanical algorithm for database search (STOC 1996) — ACM. https://doi.org/10.1145/237814.237866 (peer-reviewed article)
13. M. Amy et al. — Estimating the cost of generic quantum pre-image attacks on SHA-2 and SHA-3 (SAC 2016; arXiv:1603.09383) — Springer / arXiv. https://arxiv.org/abs/1603.09383 (peer-reviewed article: SHA-256 about 2^153.8 surface-code cycles on 2^12.6 logical qubits; SHA3-256 about 2^146.5 cycles on 2^20)
14. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
15. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)
16. M. Roetteler, M. Naehrig, K. Svore, K. Lauter — Quantum resource estimates for computing elliptic curve discrete logarithms (ASIACRYPT 2017) — IACR / arXiv. https://arxiv.org/abs/1706.06752 (peer-reviewed article: at most 9n + 2⌈log2 n⌉ + 10 qubits and 448 n^3 log2 n + 4090 n^3 Toffoli gates)
17. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/ipd (initial public draft (November 2024); proposes deprecating quantum-vulnerable public-key algorithms after 2030 and disallowing them after 2035 — dates may change in the final version)
18. NIST SP 800-57 Part 1 Rev. 5 — Recommendation for Key Management — NIST. https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final (final (2020))
19. NIST — Post-Quantum Cryptography Standardization: Evaluation Criteria, Security (Call for Proposals, Section 4.A.5) — NIST. https://csrc.nist.gov/Projects/Post-Quantum-Cryptography/Post-Quantum-Cryptography-Standardization/Evaluation-Criteria/Security-(Evaluation-Criteria) (security categories: AES-128 key search 2^170/MAXDEPTH quantum gates, AES-192 2^233/MAXDEPTH, AES-256 2^298/MAXDEPTH; MAXDEPTH 2^40–2^96)
20. OSV advisory GHSA-27r3-jxmh-p828 — OSV.dev. https://osv.dev/vulnerability/GHSA-27r3-jxmh-p828 (modified 2026-10-23T21:00:06.131613693Z)
21. OSV advisory GHSA-2vr4-cq9g-pvrc — OSV.dev. https://osv.dev/vulnerability/GHSA-2vr4-cq9g-pvrc (modified 2026-09-28T21:00:05.355682124Z)

22. OSV advisory GHSA-4mjr-xmp4-gh2g — OSV.dev. https://osv.dev/vulnerability/GHSA-4mjr-xmp4-gh2g (modified 2026-09-10T03:51:14.991984096Z)
23. OSV advisory GHSA-6j4f-fj2g-mc7p — OSV.dev. https://osv.dev/vulnerability/GHSA-6j4f-fj2g-mc7p (modified 2026-09-30T00:00:03.836613572Z)
24. OSV advisory GHSA-6pq8-jhm2-2vcw — OSV.dev. https://osv.dev/vulnerability/GHSA-6pq8-jhm2-2vcw (modified 2026-10-27T16:15:05.324423680Z)
25. OSV advisory GHSA-848j-6mx2-7j84 — OSV.dev. https://osv.dev/vulnerability/GHSA-848j-6mx2-7j84 (modified 2026-09-10T03:50:32.794069999Z)
26. OSV advisory GHSA-ch52-4w7c-c8xp — OSV.dev. https://osv.dev/vulnerability/GHSA-ch52-4w7c-c8xp (modified 2026-10-02T22:45:04.334960361Z)
27. OSV advisory GHSA-h3mg-xc3c-68pw — OSV.dev. https://osv.dev/vulnerability/GHSA-h3mg-xc3c-68pw (modified 2026-09-30T00:00:04.407982988Z)
28. OSV advisory GHSA-j6r3-76f7-8jcv — OSV.dev. https://osv.dev/vulnerability/GHSA-j6r3-76f7-8jcv (modified 2026-09-30T00:00:03.843448355Z)
29. OSV advisory GHSA-jqcg-44mw-7w3h — OSV.dev. https://osv.dev/vulnerability/GHSA-jqcg-44mw-7w3h (modified 2026-10-05T23:45:07.322157228Z)
30. OSV advisory GHSA-q2hr-2g5m-vwhr — OSV.dev. https://osv.dev/vulnerability/GHSA-q2hr-2g5m-vwhr (modified 2026-09-30T00:00:03.849541183Z)
31. OSV advisory GHSA-qhr7-859c-m2p7 — OSV.dev. https://osv.dev/vulnerability/GHSA-qhr7-859c-m2p7 (modified 2026-09-30T00:00:04.402763332Z)
32. OSV advisory GHSA-rpw4-54j3-4h4q — OSV.dev. https://osv.dev/vulnerability/GHSA-rpw4-54j3-4h4q (modified 2026-09-28T21:00:05.359993143Z)
33. OSV advisory GHSA-rxp7-6hxx-x8q5 — OSV.dev. https://osv.dev/vulnerability/GHSA-rxp7-6hxx-x8q5 (modified 2026-10-22T16:30:30.129356757Z)
34. OSV advisory GHSA-x5fp-wj9c-mxmx — OSV.dev. https://osv.dev/vulnerability/GHSA-x5fp-wj9c-mxmx (modified 2026-09-10T03:50:54.569331980Z)
35. OSV.dev — open-source vulnerability database and API — Open Source Security Foundation. https://osv.dev/ (the database QSI queries for each exactly pinned version; every advisory id in a finding resolves at https://osv.dev/vulnerability/<id>)
36. OWASP Application Security Verification Standard — OWASP. https://owasp.org/www-project-application-security-verification-standard/ (living standard — check the project page for the current version)
37. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
38. R. Babbush et al. — Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations (arXiv:2603.28846) — arXiv. https://arxiv.org/abs/2603.28846 (preprint (2026-03-30, v2 2026-04-15): 256-bit ECDLP with < 1200 logical qubits and < 90 M Toffoli gates (or < 1450 and < 70 M); < 500,000 physical qubits at 10^-3 error, minutes)
39. S. Jaques, M. Naehrig, M. Roetteler, F. Virdia — Implementing Grover oracles for quantum key search on AES and LowMC (EUROCRYPT 2020; arXiv:1910.01700) — Springer / arXiv. https://arxiv.org/abs/1910.01700 (peer-reviewed article: lower cost estimates for the AES key searches that define the NIST categories)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
SHA-2	SHA-384	DEMO.md (line 167)	сниженный запас (Гровер), одобрен	допустимо
SHA-2	SHA-256	packages/oci/src/registry.ts:525	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	допустимо
Crypto library @noble/hashes (noble-hashes)	1.4.0	package-lock.json	н/п	допустимо
Crypto library jose (jose (Node))	4.15.9	package-lock.json	н/п	допустимо
Crypto library jose (jose (Node))	5.9.6	package-lock.json	н/п	допустимо
Crypto library elliptic (elliptic (Node))	6.6.1	package-lock.json	н/п	допустимо
Crypto library elliptic (elliptic (Node))	^6.6.1	packages/conformance/package.json	н/п	допустимо
ECDSA	secp256r1	DEMO.md (line 167) — (empty)	уязвим (Шор)	допустимо
ECDSA	secp256r1	packages/cli/src/signer.ts (line 12)	уязвим (Шор)	допустимо
ECDSA	P-256	packages/conformance/src/commands/verify-bundle.ts:189	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 dc5dfd0611af59e5724beaee5a3151159457f67dc81deebe8ed4ff09b683b1cb

C. Входные файлы

Файл	Размер	SHA-256	Маскирования
DEMO.md	13568	`c2f21d5948090c477ff0a027464fe6f5ec42ceeffe6d198392f2b0584bf5e5b1`	0
eslint.config.mjs	493	`c691c02729543097255f524dea11840ac52feb4e9235aab88fbaf81fa21c3022`	0
jest.config.base.js	426	`637539431bdcdbae8cc284c11c87c3ab2b55efbb46f3dfc721501c9bff1720a2`	0
jest.config.js	776	`aa5ff5781e838d7f095742640a48d68ce13174caebe5fc734020e2e4bff80ed1`	0
package-lock.json	350932	`e2833a204528b90b7a76f2a5f84377ea36b3ebabd73984c7bc31db294b5f259f`	0

package.json	1640	b85dbfb2ad127243d55548caa35b0759dd96538f78384a8deee1e7b583bcd0a4	0
packages/bundle/jest.config.js	722	f7fcba7d58570de738b553090dd5e919e3bb2f0b0031af7dcfdb19b079a738b6	0
packages/bundle/package.json	822	410d257b34acb53ca90eec9663e626a040de96e1f2e6e069913a32d4287e1e98	0
packages/bundle/src/build.ts	3677	50f61e56756b92384b04b00f42458c091de5e795c77958474d1875c6a1a93342	0
packages/bundle/src/bundle.ts	4685	27e3c3f60a5c67b5a49660f0b2897fa6e9be9b3c0dd6ac40db2cb73bd73e4fde	0
packages/bundle/src/error.ts	737	05fa8580885836c338842dde908bba8bf9d629d2189e8b461df8b055a114d258	0
packages/bundle/src/index.ts	1786	c849688e8be888f17773366736aca90d8a309d84ea9d7a24dc1071895930cf21	0
packages/bundle/src/serialized.ts	3262	f7f14054df2f232e0dc3a418ec27aefb6313c615dfd3208fe30cd1470bb45d90	0
packages/bundle/src/utility.ts	1435	7a54e85e33ed0bb59b6dfa184d6700d60cb8e1e5cf743ea039aa4ed18674be2c	0
packages/bundle/src/validate.ts	7726	cc8a1d07a17055aa80f1172f06ea20ffbea76b6f38c3553a1c84eeeaaa652476	0
packages/cli/jest.config.js	719	43bb99376209161159ac9c582743ed70018d005e527c97953efacf174b28af0b	0
packages/cli/package.json	1711	f2c9a78a76cde4170f06119f4ffc8bd7c91944a488d7b0d4c1e39df3cf8a1f77	0
packages/cli/src/commands/attach.ts	3564	a6b706d18f5eb73d9df861f52896eb90c8816e5a72859dd8022571dfd66b0899	0
packages/cli/src/commands/attest.ts	5554	ea63d2cc6a522d51e623b5fb71f68b0c0bd9f29ae25666b3f380867a55191d5e	0
packages/cli/src/commands/initialize.ts	1230	203e6713334ddf533c87906d12181c69fa25635f87755d9d2f906f16967cb75e	0
packages/cli/src/commands/token.ts	1253	33229416c6220dd2c2ee8515a093f5b94a7cdb173b5a5c192cf463e93b0751ca	0
packages/cli/src/commands/verify.ts	3951	0744a705d7ff0bcd5e8566ab32d9a1ead998ff68bb0e8907d87f06d895dcb026	0
packages/cli/src/index.ts	35	658d7ae3d7654cb926a4d20defc7b8ff80e4f07c48b72f8daf118ca1dbb19cf6	0
packages/cli/src/oauth/client.ts	2014	c048c5d196536e16edbc05c2fbcea825174f68af4c10a292ee49767fad8266c5	0
packages/cli/src/oauth/index.ts	1760	a7ff70aea3070dc39f70c62dcb89922e94df0f93db8f0a4144d1127455b080b2	0
packages/cli/src/oauth/server.ts	11856	d5eb4c3c60851a7dcd8c04fb44354240a69bf9b74a0f6781c3f656c9c99cc7f6	0

packages/cli/src/oci/name.ts	2855	3c0aa754f029c5dabeab7ffb3c488a257908777d20f1c824790383c314459d43	0
packages/cli/src/signer.ts	1080	26c2716645d88c4a850d5d8c7e6753f349694b8e5a58de17baf2a484a96fe0f2	1
packages/client/jest.config.js	905	0a83121f31579b292d1dc792023b946729389f41556a7a44bf6fd346a38731df	0
packages/client/jest.setup.ts	666	c9f73b74f8ee642323f97640a7fb929539d3c1f64640d3b886efbb111870955f	0
packages/client/package.json	1194	efdd5c6b58f7f179aa562c2a467e387dbe1f08b54a51f553932963043ad0695d	0
packages/client/src/config.ts	6099	85b4951d6395ec52120533a94285cac288eb3532d417dd704a7e3b68e6b86842	0
packages/client/src/index.ts	1125	ac3e12c6975e4b4885d13d238f11a832caf5e1c1fbb8e4af6984e8e1f2bc7e00	0
packages/client/src/sigstore.ts	3389	99c3989b7514310a14a1b762d4f8f853b8be822556c3ad2033a7420f637f7e51	0
packages/conformance/package.json	889	a0cf9636b3dda00af7d9139111bb7fad5cec16d17be2f571cf7c1bd0feef6637	0
packages/conformance/src/commands/sign-bundle.ts	2486	553f8bc97a7dcdcc2eae315bcfc1cab5b92becb1847ca7839b88de4e5a9a043d	0
packages/conformance/src/commands/verify-bundle.ts	5800	51b04961ad1221e9614164ecf7c12eb9f293188f8174e47dd4e1f567890299a4	0
packages/conformance/src/config.ts	946	d9c2639deb1c85ae95b3cb2d5ecd4ff946cb8bfc5d18f3cc6c2529a774c86cf5	0
packages/conformance/src/index.ts	35	658d7ae3d7654cb926a4d20defc7b8ff80e4f07c48b72f8daf118ca1dbb19cf6	0
packages/conformance/src/staging.ts	2731	0d9e5a586d2440bbd5ea861671d15cfadebb7b0037bf78f0dcaca81c33f69302	0
packages/conformance/src/trust.ts	1208	80b12bdb79027c27d3feeb0d4ae2a6d76c90c5cb45885e9e06fb9f2d1742515d	0
packages/core/jest.config.js	867	fb9d113e180071fb9531daef91d031ecde316166072a50cfa9296ffeeddf249e	0
packages/core/package.json	744	55d00d9cfae15f310382659245d3829fc9a5a615953bf8691127bbb80d1bd44a	0

packages/core/src/asn1/error.ts	658	a7dea5be3a44ce8c2fa164090b7658061bd6e545e6fc98a7fa92bdf12e35e05d	0
packages/core/src/asn1/index.ts	601	eac3094da7f07fd1cb6cf550ad04d9a29d33a3dd9d9e3fb99bcbb1f895290aff	0
packages/core/src/asn1/length.ts	2653	aa6b66528a53973f8eff0575ab8b10065fad2507eaf2836bb394d143d463110e	0
packages/core/src/asn1/obj.ts	6356	f318e3ca7e25b05b59708eabac05b882d36883eb52d4f5f6fbbe7a9093d90c90	0
packages/core/src/asn1/parse.ts	4892	b9891143b331b39515d746adecfdaa95d8ad1298cfea858a7cf54a2f326d4225	0
packages/core/src/asn1/tag.ts	2828	5bab7586b0f84626c2e6d70400e5d1c454893552caac947db840c32acf806630	0
packages/core/src/crypto.ts	2006	4475b75ab49f1f8b899cd9d92acc2b413447fd1d855faff2c2e703b8429ff504	0
packages/core/src/dsse.ts	944	d79190ca5fe9d776076a4c45dad4939734b2ff212f6152802aa6136f69a62636	0
packages/core/src/encoding.ts	879	b7a10c1de805664d770157d0a3ed042662c2c0df367d8958a6b559a6ea3bf53a	0
packages/core/src/index.ts	936	d1e340dff21774a15f7ba9aaf63acfef637263fb7092e5df9113d9649a7e86b5	0
packages/core/src/json.ts	1704	a43fe84c9f98d6d4ba264bacaf6a5b890d7e0c89658bae7a2e689a9f3e741bb4	0
packages/core/src/oid.ts	594	a8c01bebb7ee60e477d43f5453180fa053b06cffc2460bd09acf8ae58b8479e4	0
packages/core/src/pem.ts	1467	37e69a367e9f133ad96534df6d7a72b894c53a6c0a5bae48460994ff5e4fb7dc	0
packages/core/src/rfc3161/error.ts	632	724da1706e0ba8b19233b7514cba6a10ad67798843ddf35f0becf2f266f11ec8	0
packages/core/src/rfc3161/index.ts	617	cde20613032d9f8c24f9c92aaef5382a8b86d907afa4cf946b0af3a369155654	0
packages/core/src/rfc3161/timestamp.ts	7306	4a98fb11194133fe2928a888db43912c7bc3f8e9dd32eb79e580b9b2c01d08c4	0
packages/core/src/rfc3161/tstinfo.ts	1741	d817764a80290880f5cb39b0bf4b34441bcf97566d1137df6948f80b9693f853	0
packages/core/src/stream.ts	3423	9772a49d5da1fbe486f098721ff3337ccf930415521104df789e3454c06339df	0
packages/core/src/x509/cert.ts	8731	e2aebed8715cc3a9eaa79803db2eb4cd48283e7274397c717c4e2d897a718d49	0
packages/core/src/x509/ext.ts	5612	4e206132eaac9fcac85ceba751c32b9ed476c0aee70d5dda718066277ded1a84	0

packages/core/src/x509/index.ts	672	2c0ea4fe5f11e43c3609a76a8a48c1720e2926242c46f2ad161db1e35097e705	0
packages/core/src/x509/sct.ts	4579	cd8c9c9f6e902dbce3142675a26ad4da352f9409438cf1d432cbf6e8f7f88bef	0
packages/jest/all.js	628	341cf2aac41eb5b87239934600771b51c653afc875a427041ef6720a3a4a9614	0
packages/jest/package.json	620	28879d1986c5a06d25396f5e7d565d58ac3db3cdc44da40a4b780dd544f7da30	0
packages/jest/src/all/index.ts	943	45404325eafff708451f397081da902677b88814ab29478abadc43f0b07ac6b3	0
packages/jest/src/index.ts	596	dfb59a47f64341f90ef117786e6b093366d8d6bf63be23580c2b95a7e4b4745d	0
packages/jest/src/matchers/index.ts	621	ae3b010e0cd332735d421351818d3f5e078a967bfb0a3f5cfb7f26d0de06563c	0
packages/jest/src/matchers/toThrowWithCode.ts	2291	6fb7781d49eb31b56b40bb7a8c76e53c6ad5764d5c35703e88c2da9b476bd19d	0
packages/jest-types/index.d.ts	429	2184e8e02fdcff2da3c5c9423f215d2247ef6b0fd7a6ca49d07a0465cd656d6e	0
packages/jest-types/package.json	577	867c25b1356703d4d451a5c2c3347fa9df609311462484969bc6ec94cc358366	0
packages/oci/jest.config.js	866	f2839c26ba6c332f977f3dd3f2e79c4e88e1063fbe6913bfe50efd23ba6a62ac	0
packages/oci/package.json	929	72a843fb42bf2ed669a0183558a43b5129e065d786843bfc9dd8c988e302abd2	0
packages/oci/src/constants.ts	1652	66457970d8105a8b82a6f8a4db81f95eda9760d3bf0a50cdfaae6dc484ed90d5	0
packages/oci/src/credentials.ts	3848	5bc124487c9901e336d973b6eb6642720860279936c0ad642ff89b49a281a625	0
packages/oci/src/error.ts	1687	3c71e95a4ee19b38965480e67635bfd8d23eed1944e46c0527ea8fc324c9342c	0
packages/oci/src/fetch.ts	3304	011fbaa6a35b2c87ab659e4f1ed3e4347bd23b760d92bf628d64808dcfe1b38a	0
packages/oci/src/image.ts	7598	f35546c20fe4961780bd54df08998683ad91c8282e73efd78baf11133bd1d907	0
packages/oci/src/index.ts	2010	99513b6ad7a7ec7f86081dd6de8666f9451c4ae1c4fba7d5bfb6f31466c77a1c	0
packages/oci/src/name.ts	2666	ecaf9616322cb0bc576224d2b98faf6bd453ee8b288d373d9c6d6e7ecaf2a88e	0
packages/oci/src/proc-log.d.ts	111	6f6e66f2f24b44bf6b37a5c55ca416383a209e97d6fb71c6f7f941975126de71	0

packages/oci/src/registry.ts	17725	baa50257dfbbd53a145f02dcf2e768a48ea339ce4a02be773214df1b8a236adb	0
packages/oci/src/types.ts	1651	09ec8ef3535f3528cf075c1682981be56e7df16c26168104ad53939674f752ed	0
packages/rekor-types/jest.config.js	727	1f045013467c48bae5ef1dae2c68c033059715b0fafbc7c4584165883ffcdfeb	0
packages/rekor-types/package.json	926	c6c0572d1458ef1cd6b617a5920d9c66f61042ae0a54be310481423f8c45e1bc	0
packages/rekor-types/src/__generated__/dsse.ts	2227	0602db1483fe31f33733fade106640002c245271477dd6796373032bab0e8464	0
packages/rekor-types/src/__generated__/hashedrekord.ts	1409	121aeff17a43605a2512c5f71b3b8f45d361140f74a3f0631628827d5d77ce0e	0
packages/rekor-types/src/__generated__/index.ts	1166	ad438c8a2ca3a3b843bc043b0e8f73c8ac41df9d9b936e79425f34b180ff1de6	0
packages/rekor-types/src/__generated__/intoto.ts	3146	05a15eb36b69d4559c94d9a68c5753148e18639a79750f29b155a90b87ba5663	0
packages/rekor-types/src/__generated__/models/ConsistencyProof.ts	331	b64baaa84da926dd9442c278c6c3da5533dc129d0b35b42890fffbfb14790cb8	0
packages/rekor-types/src/__generated__/models/Error.ts	200	4a3841d3f169e4f4996adcb201d3a587e04b743aea9d651350fa5fd6edb1a1cb	0
packages/rekor-types/src/__generated__/models/InactiveShardLogInfo.ts	514	6894abcdfb915e320d91223ec5c6bdac694025ad5f85001dec711605bdb3b3be	0
packages/rekor-types/src/__generated__/models/InclusionProof.ts	773	8869bd4fa7a20b0f189faf35aad33d7483f831193075e35e63de43325ca05e5f	0
packages/rekor-types/src/__generated__/models/LogEntry.ts	797	fbe283add22d3400329a54e2b80d1bd303dd07d537fcf915ecddf44e93cd3094	0
packages/rekor-types/src/__generated__/models/LogInfo.ts	619	d151624259aadc6aaadbd0025034fa8df36e9a3ec80009cffdd8629ab1b722ab	0
packages/rekor-types/src/__generated__/models/ProposedEntry.ts	185	a7a6ff101ee2194b1b86efbd10e16ed2b3d7cf5f2268bcab4d488a09bfb448ce	0

packages/rekor-types/src/__generated__/models/SearchIndex.ts	367	592a0d73be79239787d28da7cc960af0f773c340faac84f6b52444a2bfda95a7	0
packages/rekor-types/src/__generated__/models/SearchLogQuery.ts	322	fa510f2ef8553e28999fbbb9700906e17d1410662abba1b41441a5b989b86c00	0
packages/rekor-types/src/__generated__/models/alpine.ts	250	c1f7b51ad5f718243073d62e6d3927ede450e2e6e45f51122112d35e981ee58a	0
packages/rekor-types/src/__generated__/models/cose.ts	245	9977d013c513ce371e52e2d8eb3ee10b4da9cb4a8ab6d3fbffe8af5c1fc6cb16	0
packages/rekor-types/src/__generated__/models/dsse.ts	247	1c50ae26dde14d31064e178f67a71f283363ca1e37165b600a7bcfe78138f682	0
packages/rekor-types/src/__generated__/models/hashedrekord.ts	262	afe069460c147ca3cafa8380d0a2ec1a608cfe7e78deb9e5868830ecca3ded63	0
packages/rekor-types/src/__generated__/models/helm.ts	244	036676b5ef73be92d06cce5ae8f25548456d72291a791c256948b5c6e6cf3caf	0
packages/rekor-types/src/__generated__/models/intoto.ts	249	947341799005317f5f5a6939b6664b04b0a9aaa62ae2d230a073c9c24952691f	0
packages/rekor-types/src/__generated__/models/jar.ts	251	9a8fc649a58086ea53aa4c215d47a101097d8ecb61a25c0ddad22211cdf85f80	0
packages/rekor-types/src/__generated__/models/rekord.ts	249	adab4cd24e42b7ae9e012c952318af3082718d04a1154b833fbd03031c9fa44c	0
packages/rekor-types/src/__generated__/models/rfc3161.ts	254	e0205acc27a299a3c33a96dce6c899aa14ea6f229d104bd95a7dfbe978362207	0
packages/rekor-types/src/__generated__/models/rpm.ts	244	37558a5ad94a4660052a0fa450c099d3598bfe833bbeaa310f38df95afe57c07	0
packages/rekor-types/src/__generated__/models/tuf.ts	245	d68ba8e533cd54d7182b08aac2cef25e58b032d923e7f025b3effcbf58c77433	0
packages/rekor-types/src/index.ts	1450	5ac087652aab7d9dc44098556126725fe5eea744b6fcebff97d6f3ae3fc7b85b	0
packages/sign/jest.config.js	765	1aaf769eeda28d463de658a2962ae386dda98d07fdc27331d84f9ed2708dbcf7	0

packages/sign/package.json	1147	952ed4be6332294975a9c1359a288b907da2494c1861e2d661fc42e0198713d1	0
packages/sign/src/bundler/base.ts	3839	71103abd968908fc83deb299de3bc495a83ef2c5a5d5842074ca789fc22ec27e	0
packages/sign/src/bundler/bundle.ts	1983	103d38d34ea5b6326b9bad24e0ac09f1fd4af65e30ecb5470efe7d51dd3501e3	0
packages/sign/src/bundler/dsse.ts	2215	bf2eb6cdcab211754a475e9a4582e0bc4ef6b9082caf92df2361901c3896d8db	0
packages/sign/src/bundler/index.ts	748	a0ce1f1a078714c3729d7a603b4d2a20f59ae003768d39f70e5933926305f0e3	0
packages/sign/src/bundler/message.ts	1233	11c8ed6fa67593ac17491fa8a73a86e685b493a09e089ece6bdb26f410f4d3f4	0
packages/sign/src/config.ts	6619	3734eb0b274577b71d12bf4a169bc01467a68d9c6dce3ac22b981c7b30eb933b	0
packages/sign/src/error.ts	1515	113ec63f4c69bd539703cd1c0eba8268ddf725176adcdbc5707a380aed9dcd7a	0
packages/sign/src/external/error.ts	902	84c2e1487c1c40b76ecf3398dc444316b6546dcf895100ef08e3f8baaf5a77c9	0
packages/sign/src/external/fetch.ts	3599	06b4cf4453d655ebde6424c95e4957a8dee28ffcf2203b16407b6737c62f281e	0
packages/sign/src/external/fulcio.ts	1835	fa8be03ed092e668c209ac91d1e94d1812aa27accf393391587833e85820a5fe	0
packages/sign/src/external/rekor-v2.ts	1598	17679bb49d6c56e5bebea4017020f625c4d952e79e4233f60f5a68609fb48fa5	0
packages/sign/src/external/rekor.ts	3148	41fca8e0dc67fcb753d98118913f5db16b0dde9823f9a1443cabe57c3ccef2e4	0
packages/sign/src/external/tsa.ts	1737	3a9cfac918b112af7adaa755eb83a54a9757522bf18b79e53e58c4f31cf94324	0
packages/sign/src/identity/ci.ts	2654	ffe64422695d607316e89832e545138aa3f8ac8c5b2b239595417a8a7e8390a0	0
packages/sign/src/identity/index.ts	662	ef3b4982b763222a68cc8be437d04cb86001348a6c27cc8415d2e221ca1b1730	0
packages/sign/src/identity/provider.ts	737	ba7e8ac69cc1ed3bfae9fdd26a89314c5da26cb9eaca54130105520f997d7430	0
packages/sign/src/index.ts	744	00b45bdd4bc6e5bac13fe7aabc2e4ebc7558ed823f0f84b36d4d0528c3b255ba	0
packages/sign/src/proc-log.d.ts	111	6f6e66f2f24b44bf6b37a5c55ca416383a209e97d6fb71c6f7f941975126de71	0
packages/sign/src/signer/fulcio/ca.ts	2402	4a404491828689246d7a0c56ca49d54851da7155274c0f1c9b5e1d93e212e54d	0

packages/sign/src/signer/fulcio/ephemeral.ts	1498	5e8f22f769bc20ac14a5256c82acdbc2f8dbb12652af4f08ce8b13bee94b84a3	0
packages/sign/src/signer/fulcio/index.ts	3485	9407869b2cd2e9f5b9484358ebbdc4247893793f293eb014d1f14e16778d0080	0
packages/sign/src/signer/index.ts	749	7140ea73a18fc3f8cf29faa53ad271b095e52a19b3dc7de8af1aa85343f9ba39	0
packages/sign/src/signer/signer.ts	1358	880db8ac2bb4f481666b3f8f529a5a945b6a64faf117656b09d92773cd4674f5	0
packages/sign/src/types/fetch.ts	769	89afe352294b0cf11999d68536acc4aa864811dcb5c92fe5595540c13ada4b86	0
packages/sign/src/util/index.ts	696	a8911bc2d54d38473487cab244c97b6a61e06a78f0127e6a4eaf12c4b344289b	0
packages/sign/src/util/oidc.ts	1142	fca6bb0888d1e37929c900d5a78d5a43171832d82ed528c65055197db9292b44	0
packages/sign/src/util/ua.ts	1047	e7038d20913b0247738422fc49466d5ce1e841f8a9927cc5f60679cbf3cf26cd	0
packages/sign/src/witness/index.ts	811	dd5550a80436a18fa5c014711650ac13521ff2ed4dd91f12145f5194af87558d	0
packages/sign/src/witness/tlog/client.ts	3911	5b5f3795a70a453b8bf1773a798681287e4bab06b8a90e0be843ccc4e7cb4a52	0
packages/sign/src/witness/tlog/entry.ts	7619	d5d2711c2ea737c8b869bcda67895e27c10ac5eefbc71de027eab98a5579035d	0
packages/sign/src/witness/tlog/index.ts	4042	4d0882e2c9e7ce0a3dc3fc38782485205657ea3171b470cfe7df56763235614a	0
packages/sign/src/witness/tsa/client.ts	1677	e127bc4328529581714ff36f20e8ebf1d86dc06423b3185b44de065abd12a2f4	0
packages/sign/src/witness/tsa/index.ts	1676	394b1df28f8b8b9820a3cf57e561fda862c789ce4e4731357078be2113718e9a	0
packages/sign/src/witness/witness.ts	1109	a9774d818bfc12a69ae9b0508ef486d112fe822acd5308e7b9442b4494c42806	0
packages/tuf/jest.config.js	765	5ff30ff435cef2ad9fcb3f116469b7a7f4b4f7475e46c4e0a64ab224d82e5d50	0
packages/tuf/package.json	999	d9744179103dd60c3c8d63caf6ecc3acfb1f8b040a0ae4e3adc790833a12ba59	0
packages/tuf/src/appdata.ts	1319	661febabdca25f98d1ae3bcc74d5ad09eae5f8777d2285f2992e79cbf6f89f53	0
packages/tuf/src/client.ts	4891	a65c0d8a01a3cd2a714ae4b28981e5def3d0b546d2f89519fa1494cc7696c1cd	0
packages/tuf/src/error.ts	1127	757c92fc436b00670a8437a88f9609cdbc72b82c7dcc572d4cbd4a87cae0124a	0

packages/tuf/src/index.ts	2174	3e598640e0481d4360dc680433bb3a7e45e83d3cb0e4e8160e9d6ba4ef8d7edb	0
packages/tuf/src/target.ts	2370	82986aff025886dd6e2907d687c87097f58b46e21ee9eb7de4a4c08c22746b6c	0
packages/verify/jest.config.js	869	47080e428ad7d478822538f1a2828cc44d8c0ab4d99630e59b4186c62dd1ac18	0
packages/verify/package.json	890	69fbaca3493e35b5fb399a4cd0788af0956e20efbb223d2cdbba3d8e2c5c3743	0
packages/verify/src/bundle/dsse.ts	1989	4c8086ec138c2afba83696ea5466a50978568bbf1ef0c30af8f77d14019daed5	0
packages/verify/src/bundle/index.ts	2768	c5b100a83bc4e2f509535a35344c2ec62e1c4725372037a0dcb5866e26f326c7	0
packages/verify/src/bundle/message.ts	2449	fa2f0f87c5384ca9b0c1c6c600265df7927a929518c30456276cbaad589ac44c	0
packages/verify/src/error.ts	1483	9191bdb39257476e153b14bb42d908756648b56b43cd963a1a90dd612dbaf7aa	0
packages/verify/src/index.ts	982	228a5d96e9419fc068ffef638dd6d05f6679c62745fd916a7747c4c43113100d	0
packages/verify/src/key/certificate.ts	8669	a91193c5a43b9a07b6452a193cb2a8d74cc39cad9c3d11e2bb0270034a90b772	0
packages/verify/src/key/index.ts	2969	6386e6efe3ef3467282769bc9c432b4da0d5251e094088839565f5fd0a38e85e	0
packages/verify/src/key/sct.ts	3287	1c76d3253b32b1919d03a5c38340c94ea992a5e5d6a80414459660872f79d006	0
packages/verify/src/policy.ts	2114	0050f60baecb23625ee8837080283a1d361384f87cd800f65f4593848541c85f	0
packages/verify/src/shared.types.ts	2964	8e2f27302c60ec68f7d62ea03a111725ea54d41362111c186e96457cf03b96ba	0
packages/verify/src/timestamp/index.ts	1692	584e17d3bfa3ac61226068c431732f5c78ff08e3b2551aa59814c137b085c2c6	0
packages/verify/src/timestamp/tsa.ts	2480	3ac0891fe120e1f5565b5b36f364d6a714f18241d146eebc75a5776d7567570e	0
packages/verify/src/tlog/checkpoint.ts	7120	c0bd7ba6538759c8ca9c1f49232b78a59ff6814206f144be2f85618034d72149	0
packages/verify/src/tlog/dsse.ts	4053	a24318332912d4214bd066dd2c7a3cc0148910f3a636f87ee9a99a8923dca6c5	0
packages/verify/src/tlog/hashedrekord.ts	3698	d854e4f51783416b36d289ad394440ff7182315e593941d126847d4a82fc625c	0
packages/verify/src/tlog/index.ts	4148	095aa6a11f2e2bb3c4c24752f5f6612524d69cad8c5522896283bb905aea4eed	0

packages/verify/src/tlog/intoto.ts	2514	528a6950e728ec4c366c584344e435dde79b30d34547c2303d51491384640a8f	0
packages/verify/src/tlog/merkle.ts	4695	a253d2d630729e9b996eed48353521d208b1de2283e7f563d8d8f71f713922bc	0
packages/verify/src/tlog/set.ts	2753	877cf1bf8d32a7d26dfcc8cab7a991938da69ca40dbcb19a8fdcce194178c0c2	0
packages/verify/src/trust/filter.ts	1666	077967357eb0fa72dbdcd913e12373b668dbbf85acf70f6b4ceaa77ee200dd2d	0
packages/verify/src/trust/index.ts	3657	bf60e46355143997aba300dc6e7cabdb61d3f1a4d1600885d1865a73c5de467c	0
packages/verify/src/trust/trust.types.ts	1269	d9ee4d86a01ca310a374e769db8108947afae21750bb8a07c80010aa82a9671c	0
packages/verify/src/verifier.ts	7290	dfb85caca2a453e139176de9b51156a8ef78d21adae1d845794f0136262224b1	0